

Validation Notes

Project Title

Security Validation and Compliance Evidence Compilation

Validation Date

15 May 2026

Target Application

[OWASP Juice Shop Demo](#)

1. Purpose of Validation

The purpose of this validation activity was to evaluate the security posture of the target web application using OWASP ZAP. The validation process aimed to identify vulnerabilities, assess associated risks, and compile compliance evidence for audit and review purposes.

2. Validation Activities Performed

The following activities were completed during validation:

Activity	Status
OWASP ZAP installation	Completed
Automated security scan	Completed
Vulnerability identification	Completed
Risk classification	Completed
Evidence collection	Completed
Compliance dossier preparation	Completed

3. Security Validation Process

Step 1 — Configure OWASP ZAP

- Installed OWASP ZAP successfully.
- Configured automated scanning mode.
- Added target application URL.

Step 2 — Perform Automated Scan

- Executed passive and active scans.
- Allowed crawler/spider to discover pages automatically.
- Monitored alerts and vulnerability detection.

Step 3 — Analyze Vulnerabilities

The following security issues were identified:

Vulnerability	Severity
Cross-Site Scripting (XSS)	High
Missing Security Headers	Medium
Cookie Without HttpOnly Flag	Medium
Information Disclosure	Low

4. Observations

- Some pages lacked recommended HTTP security headers.
- User input validation was weak on certain forms.
- Cookies required stronger security configuration.
- Security alerts generated by OWASP ZAP provided useful evidence for analysis.

5. Risk Assessment Summary

Risk ID	Risk Level
VR-01	Critical
VR-02	Moderate
VR-03	High
VR-04	Moderate

6. Mitigation Recommendations

Vulnerability	Recommendation
XSS	Apply input sanitization and output encoding
Missing Headers	Configure CSP and HSTS headers
Cookie Issues	Enable HttpOnly and Secure flags
Information Disclosure	Remove unnecessary server information

7. Evidence Collected

The following evidence was collected during validation:

- ZAP scan report
- Vulnerability screenshots
- Risk register
- Compliance dossier
- Validation logs

8. Conclusion

The security validation activity successfully identified multiple vulnerabilities and validation risks within the target application. Proper mitigation strategies were recommended, and all validation evidence was compiled into a structured compliance dossier for audit readiness and traceability.